



Analysing and Mitigating Vulnerabilities in a Metasploitable Environment

Edvin Topalovic

Valentino Glave

Computer Science

Bachelor's Thesis

15 ECTS Credits

Spring 2025

Supervisor: Kayode Sakariyah Adewole (Ph. D.)

Examiner: Fisseha Mekuria

Abstract

Cybercrime is a growing issue in today's fast-paced technological society. Systems all over the world become compromised due to weak security, bad configurations and public ignorance of digital hygiene. This can lead to financial losses or breach of integrity, which concerns civilian, corporate and state entities. This problem is especially common in small/medium organizations, which often lack resources and/or awareness to fulfill an adequate level of security in their digital systems. This study aims to identify and analyze common vulnerabilities within digital systems. Previous research has been done on vulnerability assessment methodologies, and experimentations that replicate specific real-world systems, but there is a gap in the research relating to general vulnerability assessments and how they relate to SMEs. The objective of this study is to investigate common cybersecurity vulnerabilities in SMEs and provide awareness related to cybersecurity practices and recommend practical mitigation strategies to counteract the identified vulnerabilities. The method used in this study consists of a combination of a Systematic Literature Review, including case studies from real security incidents, and hands-on experimentation with a Metasploitable 3 machine, which will be used to produce a comprehensive report which enables this study to provide a better understanding of cybersecurity for the public. Some technical tools in the experimentation include Nmap, SQLMap, Burp Suite, and Metasploit. The results of the experimentation revealed vulnerabilities in several areas of the system, including SQL Injection vulnerabilities, publicly accessible ports, outdated software, and credential reuse. The results also revealed how vulnerabilities were linked, where being able to exploit a single vulnerability facilitated the exploitation of other vulnerabilities. In some cases this meant being able to exploit internal services and compromise protected data without the need of performing complex penetration testing. The investigation and results of this study will help raise awareness and understanding of cybersecurity for small and medium-sized organizations.

Keywords: Cybersecurity, Vulnerability Assessment, Metasploitable 3, Small and Medium Enterprises (SMEs), Digital Hygiene, Mitigation Strategies

Acknowledgment

Deepest gratitude is extended to thesis supervisor Kayode Sakariyah Adewole. Unwavering support, insightful guidance, and continuous encouragement contributed immeasurably to the direction and quality of this thesis.

Table of Contents

Abstract.....	2
Acknowledgment.....	3
Table of Contents.....	4
List of Figures.....	6
List of Tables.....	7
1 Introduction.....	8
1.1 Problem Statement.....	8
1.2 Research Questions.....	8
1.3 Scope.....	9
1.4 Thesis Outline.....	9
2 Literature review.....	10
2.1 Digital Hygiene.....	10
2.2 Vulnerability Assessment and Threat Modeling Frameworks.....	11
2.2.1 Types of Vulnerability Assessments.....	11
2.2.2 Network Vulnerability Assessment Methodology.....	11
2.3 Real-World Breaches: Case Studies and Ethical Considerations.....	13
2.3.1 Colonial Pipeline Attack 2021 - Ransomware.....	13
2.3.2 Coop and Kaseya 2021 - Ransomware, Supply-chain.....	13
2.4 Cybercrime Trends and Their Real-World Implications.....	14
2.4.1 Emerging Threats.....	14
2.4.2 Cybersecurity measures.....	15
2.5 Related works.....	16
2.6 Research Gap.....	16
3 Method.....	17
3.1 Research Design.....	17
3.2 Systematic Literature Review Process.....	17
3.2.1 Databases.....	17
3.2.2 Keywords and Queries.....	17
3.2.3 Selection strategy.....	18
3.2.4 Complete Screening.....	18
3.2.5 Evaluation of Material and Findings.....	18
3.3 Tools, Technologies and Data Collection.....	19
3.3.1 Penetration Testing Environment.....	19
3.3.2 Reconnaissance & Scanning tools.....	19
3.3.3 Attacking tools.....	20
3.4 Experimental Setup: Metasploitable Environment.....	21
3.4.1 Metasploitable 3.....	21
4 Results.....	22
4.1 Identification of Vulnerabilities in the Metasploitable Environment.....	22
4.2 Exploitation of Vulnerabilities.....	23
4.2.1 Payroll App.....	23
4.2.2 SSH.....	23
4.2.3 MySQL.....	24
4.2.4 Docker.....	24
4.2.5 Drupal.....	24
4.2.6 FTP.....	24

4.3 Categorization of Threats Using Established Threat Modeling Frameworks.....	25
4.4 Impact Analysis and Risk Assessment.....	26
5 Mitigation Strategies.....	27
5.1 Proposed Mitigation Strategy.....	27
5.2 Implementation and Evaluation of Mitigation Measures.....	27
6 Discussion and Limitations.....	28
6.1 Analysis of Real-World Breaches and Ethical Implications.....	28
6.1.1 Poor Digital Hygiene & Credential Management.....	28
6.1.2 Patch management and supply-chain risks.....	28
6.2 Policy Implications and Recommendations for Digital Hygiene.....	29
6.3 Limitations of the Study.....	30
7 Conclusion.....	31
7.1 Future Direction of Studies.....	32
References.....	33

List of Figures

Fig 1. A visual representation of testing workflow.....	17
Fig 2. A Pie Chart of used sources categorized by type.....	18
Fig 3. Output from the database containing credentials, salaries and personal info.....	23

List of Tables

Table 1. Open ports and service versions discovered in the Metasploitable 3 (Ubuntu 14.04) environment.....	22
Table 2. Categorization of threats in the Metasploitable 3 (Ubuntu 14.04) environment using STRIDE.....	25

1 Introduction

Over the past few decades, our society has evolved in terms of efficient communication via the computer systems that serve users and organizations all over the world. These systems provide instant communication, seamless exchange of information, automation of tedious processes and most importantly of all: security and integrity. Today these systems face a challenge regarding their security and integrity. Cybercrime is on the rise and everyone is at risk of exposure to it. The impact of cybercrime extends beyond individuals and their private data, but also enterprises, governments and critical infrastructure that society depends on. As the dependence of computer systems grows, the need for robust and reliable cybersecurity becomes increasingly more important than ever.

Unfortunately, many organizations, particularly small and medium-sized enterprises (SMEs), lack the resources, expertise, or awareness to implement basic security measures [1]. These gaps leave systems vulnerable to attack, often due to poor configurations, outdated software and unsafe user practices which may be referred to as poor digital hygiene.

SMEs have a tendency to rely on third-party tools, but often lack dedicated security teams or formal training [1]. This makes them appealing targets for threat actors who look for weak entry points into bigger supply chains, or simply low-effort victims for ransomware attacks. Studies show that many SMEs are not only technically unprepared, but are also weakened in terms of staff awareness, and risk mitigation strategies.

An important step towards understanding the needs for cybersecurity is to understand how cybercriminals operate but also how users interact with their systems. This thesis aims to explore this by combining a systematic literature review and a hands-on experimentation in a controlled lab environment with the goal of raising awareness, identifying vulnerabilities, and providing recommendations for mitigation strategies.

1.1 Problem Statement

In a world that is being more digitized day by day, cyber security is becoming more important than ever — for big and small organizations alike. This poses issues in various areas other than cyber security itself. It is not always feasible for SMEs to hire professional security engineers and penetration testers to secure the various digital systems and services incorporated in the organization — both economically and time-wise. Furthermore, small businesses may not always be aware of basic security standards and best practices when it comes to cyber security and information security. This fundamental security encompasses not only configurations of systems, but also secure habits and digital hygiene. This study acknowledges that the disconnect between small enterprises and cyber security practices is more apparent and critical today than ever before.

This study aims to address this problem by investigating fundamental security practices, vulnerability assessment methodologies, and performing experimentations in a controlled environment to identify common vulnerabilities of digital systems and how these vulnerabilities can be addressed and mitigated. In doing this, the study may be of educational use for small enterprises so that they may secure their systems in the most critical areas, and to provide a fundamental understanding of what securing a system entails.

1.2 Research Questions

To achieve the aim of this study, the following research questions will be addressed:

- RQ 1:** How can vulnerabilities found in a Metasploitable Environment relate to the real world?
- RQ 2:** How can common vulnerabilities be mitigated?

1.3 Scope

This study aims to identify security vulnerabilities in a controlled environment consisting of an intentionally vulnerable virtual machine running the Ubuntu version of Metasploitable 3. The scope of the study is limited to performing penetration tests and vulnerability assessments to identify vulnerabilities in Metasploitable 3 Ubuntu version, and drawing parallels to real-world systems, particularly those owned by SMEs that do not necessarily have strong security standards. The scope does not include performing fullscale vulnerability assessments across different network infrastructures, developing novel exploits, exploring zero-day vulnerabilities, and exploring Metasploitable 3 Windows version.

1.4 Thesis Outline

This thesis is organized into seven chapters.

- **Chapter 1: Introduction** – Presents the background and context for the study, describes the problem statement, research questions, and the scope of the thesis.
- **Chapter 2: Literature Review** – Explores existing research on cybersecurity, digital hygiene, vulnerability assessment methodologies, and real-world breaches. It highlights research gaps and establishes the academic foundation for the study.
- **Chapter 3: Method** – Describes the mixed-method approach combining a systematic literature review and hands-on experimentation using the Metasploitable 3 (Ubuntu) environment. It states the research design, tools, and strategies used for data collection.
- **Chapter 4: Results** – Presents the vulnerabilities discovered during the experimentation, how they were exploited, their categorization using threat modelling frameworks, and the associated risks.
- **Chapter 5: Mitigation Strategies** – Proposes and evaluates specific mitigation strategies to address the vulnerabilities discovered in the previous chapter.
- **Chapter 6: Discussion and Limitations** – Discusses the broader implications of the findings, relates them to real-world incidents and SMEs, and outlines ethical considerations and limitations of the study.
- **Chapter 7: Conclusion and Future Work** – Summarizes key findings, answers the research questions, and suggests directions for future research.

2 Literature review

This section presents the academic foundation of the research conducted in this thesis. It explores related research related to cybersecurity, digital hygiene, penetration testing, vulnerability assessments methodologies, and real-world cases of breaches. The objective is to relate the experimentation and analysis to a broader context of cybersecurity, highlight the critical relevance of known vulnerabilities commonly found in digital systems, and shed light on how structured approaches to system configurations and best practices in digital behaviors can reduce the risk of serious security vulnerabilities for SMEs.

2.1 Digital Hygiene

Digital hygiene refers to practices and behaviors that ensure the safety and security of users on any system [2], [3]. These are healthy habits to have for any individual or organization that wants to prevent unauthorized access and significantly reduce their risk of becoming a victim of cybercrime. Some of these practices and behaviours include maintaining up-to-date software, the use of strong and unique passwords, backing up important data while also being actively cautious online: Phishing emails, suspicious links and attachments is something that everyone is at risk of receiving any time they go online [4]. An estimate of 3.4 billion fraudulent emails with malicious intent are being sent daily which roughly accounts for 1.2% of all daily email traffic. Bhatt et al. concluded that “one out of every 4,200 emails sent is almost certainly a phishing attempt” [5].

Phishing emails aim to impersonate financial institutions, government authorities, social media platforms or official corporations in order to deceive their targets into handing over their private information and authentication credentials such as usernames, passwords, credit card numbers and social security numbers [6], [7]. The risks for a victim who has fallen for a phishing scam often involve financial loss, identity theft, data loss and reputational damage [8].

While there are various systems in place that enable the filtering and reduction of phishing attempts in users inboxes, the effectiveness of these measures also depend on the users digital hygiene [2]. Practicing good digital hygiene plays a crucial role in minimizing the risk of falling victim to phishing by raising awareness and promoting critical thinking about any online interactions. Phishing attempts are only one case of when practicing good digital hygiene can reduce the risk of becoming a victim of cybercrime.

2.2 Vulnerability Assessment and Threat Modeling Frameworks

In cybersecurity it is essential to understand how vulnerabilities are identified, evaluated, and prioritized. There are several methodologies suited for conducting structured vulnerability assessments and threat modeling. One such comprehensive framework is presented in *“Identifying Weaknesses: A Guide to Conducting an Effective Network Vulnerability Assessment”* by Dabit et al., which provides abstract and practical tools for network defence [9].

2.2.1 Types of Vulnerability Assessments

The paper categorizes different types of vulnerability assessments based on their scope within an organization’s infrastructure [9]:

- **External Assessments** target vulnerabilities in public-facing assets such as web servers, DNS, and email servers.
- **Internal Assessments** are focused on vulnerabilities within an organization’s internal networks and systems. This includes servers, workstations, and other devices.
- **Host-based Assessments** highlight vulnerabilities in specific systems and applications for in-depth analysis.
- **Network-based Assessments** examine vulnerabilities in broader network infrastructure including routers, switches, and firewalls.

2.2.2 Network Vulnerability Assessment Methodology

Dabit et al. outline a step-by-step vulnerability assessment methodology [9]:

I. Scope Definition

This step covers actions such as defining the objectives of the vulnerability assessment, identifying target systems/networks/applications to be assessed, specifying boundaries, and highlighting focus areas (e.g. web applications).

II. Data Collection

In this stage one compiles all relevant information to the vulnerability assessment - both technical and organizational. Examples of relevant information include system configurations, network infrastructure, and security policies. One also gathers more tangible information about assets, such as hardware, software and data repositories.

III. Threat Modeling

Threat modeling is how one investigates possible threats and attack vectors. Within an organization this may include identifying potential motives and attack scenarios. This step is crucial for recognizing potential risks and to be able to perform proper prioritizing evaluations.

IV. Vulnerability Assessment

The goal of this stage is to perform thorough vulnerability scans, usually by utilizing automated tools. This stage should be applied based on scope, and may therefore cover different areas such as web applications, mobile applications, and cloud infrastructure. In the case of investigating a network, performing network vulnerability assessments would lead to identifying vulnerabilities in network devices (e.g. routers, switches, and firewalls).

V. Vulnerability Analysis

In this step one examines the results from the vulnerability assessments. This includes assessing severity and likely impact of each identified vulnerability. It is important to take into account that vulnerabilities can be related, and in such cases the impact of an attack on one vulnerability can lead to a greater impact on the broader ecosystem. Prioritization should be based on applicability, criticality, and potential consequences. After assessing the severity, one should determine whether the identified vulnerabilities and potential impacts are likely to be exploited.

VI. Risk Assessment

Risk assessments are about estimating the general risk profile. One considers the likelihood of attacks, potential effects, and then compares that to the organization’s risk tolerance. The goal of performing risk assessments is to better prioritize vulnerabilities according to potential impact on the organization’s security and public-facing activities.

VII. Reporting

This stage aims to summarize all findings of the vulnerability assessment. One should detail vulnerabilities that have been found, their respective severity, and provide recommendations for remediation. This should be done by providing clear and tangible advice for handling vulnerabilities, supported by evidence. Evidence in this case can for example imply log files and screenshots.

VIII. Remediation and Mitigation

This is an organizational step that implies aligning with the stakeholders of the organization to address the identified vulnerabilities. More specifically, this usually means collaborating with system administrators and developers to apply patches and update related configurations. After that is done the organization should perform security checks and monitor the state of the system and how the risk profile is changing as remediation efforts are applied.

IX. Continuous Monitoring and Improvement

As a last step that connects the circular nature of this methodology, this step includes creating procedures for continuous monitoring and performing reassessments of security posture on a regular basis.

These categories help organizations customize their security evaluations depending on factors such as risk tolerance and exposure.

The paper also utilizes several standards in order to produce reliable results [9]. These include CVSS (Common Vulnerability Scoring System), which is used for rating the severity of vulnerabilities, OWASP (Open Web Application Security Protocol), which provides guidelines for web application testing, NIST (National Institute of Standards and Technology), which offers guidelines for vulnerability management, and ITIL (Information Technology Infrastructure Library), which defines best practices for businesses to improve their IT service management.

Throughout the paper's vulnerability assessments, several vulnerabilities were identified, and they were ranked by severity (critical, high, medium, and low) [9]. Among the vulnerabilities ranked as critical, the identified vulnerabilities were SQL Injection (found in a web application), Remote Code Execution (found in a web server), and Privilege Escalation (found within linux-based servers). In order to mitigate these vulnerabilities, the paper suggested that the organization include all software and systems in a strategy for implementing security fixes and patches.

2.3 Real-World Breaches: Case Studies and Ethical Considerations

This section explores several real-world case studies of security incidents that are publicly documented. It showcases the nature of the exploits, how affected companies handled the incidents, and the implications of such incidents.

2.3.1 Colonial Pipeline Attack 2021 - Ransomware

Colonial Pipeline is a pipeline company that serves refined petroleum products such as gas and heating oil to homes and businesses in the eastern and southern parts of the United States [10]. In April of 2021 they became the victim of a large scale ransomware attack that was executed by the DarkSide group [11]. This attack was possible due to leaked credentials on the dark web. The leaked credentials eventually led the group to finding an old and unused account that was linked to the organization's VPN service. Beerman et al.: "VPN services are perfect for blocking unwanted access, however they have a fatal flaw, once into the VPN there is no stopping the amount of access someone has" [11].

From here on, DarkSide quickly moved throughout the entire network before finally putting Colonial Pipeline's operations to a complete stop with ransomware which caused a massive gas shortage in the entire region [12]. The asking price for the removal of the ransomware was 4.4 million USD and that was exactly what Colonial Pipeline paid to them [11]. This was heavily criticized as it encouraged future attacks but also as it showed the world that the national cybersecurity defenses couldn't help to resolve this issue [13]. It soon became clear that the decryption tool that was provided wasn't as fast as expected and ultimately led to Colonial Pipeline using their own backups for recovery.

2.3.2 Coop and Kaseya 2021 - Ransomware, Supply-chain

Kaseya is a global tech company distributing IT management software. In 2021, they experienced a large-scale ransomware attack which compromised many Managed Service Providers (MSPs) that used the Virtual System Administrator tool (Kaseya VSA) that Kaseya provides [14]. The tool offers functionality that makes it easy for system administrators to quickly update and deploy system policies and procedures via a web portal. Several vulnerabilities were exploited by Sodinokibi, also known as REvil (Ransomware Evil), an allegedly Russian hacker group that has been involved in many other incidents such as the one affecting the JBS meat production in the US and in Australia earlier that same year [15].

On the 2nd of July 2021, the Kaseya Incident Response Team announced that there's a "potential attack against the VSA" and instructed customers to immediately shutdown their VSA servers [16]. As an immediate response, Kaseya also shutdown their own Software as a service (SaaS) servers to further protect customers who did not host their own VSA servers. Shortly after this two PowerShell scripts were offered to customers which were used to quickly detect compromised systems [17]. The first tool was the VSA Detection Tool that could scan a VSA server's files, certificate paths and other indicators of compromise. The second tool that was offered scanned endpoint devices for HKEY_LOCAL_MACHINE (HKLM) registries, other configurations and compared Kaseya certificates to real ones. It would later return a severity level of either 0, 1 or 3 [14], [17]. The results helped in identifying if a device required extra attention and investigation.

The same day that Kaseya reported that the VSA tool might've been compromised, Coop started to experience problems with their point-of-sale (POS) systems [18]. Coop is a large supermarket chain in Sweden and has just over 800 stores which had to close early when it became no longer possible to receive payments from their customers. It quickly became clear that the compromise of the VSA tool resulted in a massive ransomware attack. Coop was one of the over 800 other targets who suffered the same ransomware attack. Coops' response was to send out IT-technicians to each store for re-installation of the POS systems and during this time they also worked together with other supermarket chains and help-organizations to minimize the food waste [19].

On the 26th of July a universal decrypt key was obtained and distributed by Kaseya which reported 100% success-rate with Kaseya customers [14], [16]. Two days later Kaseya made security patches available for both self hosted and SaaS VSA servers and the patch update was completed by August.

2.4 Cybercrime Trends and Their Real-World Implications

2.4.1 Emerging Threats

I. Advanced Persistent Threats

“Advanced Persistent Threats (APTs) are the most concerning challenge in today’s cybersecurity landscape” because of their level of sophistication [20]. The attacks are typically carried out by skilled attackers who are sponsored and ordered by governments and criminal organizations [21]. The goals of the attacks are to steal information, disrupt operations for financial or political gain. Targets for APTs can be found in every major business sector: Financial services, industrial and telecommunications sectors to name a few but also entire government entities and defense operations.

APTs work in several stages and have a life cycle which involves reconnaissance, establishing foothold, lateral movement, exfiltration and post exfiltration [22]. It is important to note that such an attack doesn’t happen overnight: the threat actors prefer to observe and plan out their execution to perfection and this usually involves a long dwell time [23]. A dwell time for APTs means that attackers can have access to their target’s system for months or years.

The consequences of an APT can be devastating for an organization, this can result in anything from reputational damage to severe financial losses [20]. Governments and public infrastructures are also susceptible to an APT, where power grids, financial systems and defense operations are at risk.

II. Ransomware

Ransomware has been increasing in popularity in the cyber-crime community during recent years [24]. When this malware has been deployed to the victims systems, it quickly encrypts all personal files, locks their system and finally demands a ransom, as the name suggests.

In the early days of these types of attacks, the targeted individuals were typically instructed to pay via Western Union or MoneyGram for the undoing of the devastating attacks [25]. At the time, this was believed to be an untraceable form of payment, which was very attractive for cyber-criminals. The first ever ransomware was created by Joseph Popp in 1989 when a floppy disc was distributed to guests at a World Health Organizations conference. The initial wave of ransomware, commonly known as Ransomware 1.0, marked the beginning of a new era in cyber extortion in the early 1990s. Its prevalence diminished as it was easily detectable and mitigatable. It also became clear that the payment services used weren’t untraceable and could uncover the cyber-criminals behind the attacks.

When crypto currencies emerged, so did the next generation of ransoms, Ransomware 2.0 [25]. This generation utilized new tactics and targeted a broader set of entities: Civilians, businesses, public infrastructure and governments. The attackers were guaranteed anonymity through the use of crypto currencies [26]. WannaCry made its debut in 2017 as one of the most infamous ransomware attacks in history when it infected the British National Health System (NHS) [27]. It spread across the entire system and infected every device, disrupting healthcare services. This was possible due to a vulnerability found within the SMB service, which became patched in future versions. This generation of ransomware came to an end with new advances within cybersecurity defense strategies using machine learning and artificial intelligence.

The third and current generation of ransomware, Ransomware 3.0, utilizes the very same techniques to “hone in on their targets” [25]. Today’s resources and broad availability of machine learning and artificial intelligence make it possible to make dangerously precise attacks on specific systems. In addition to specific attacks, the attackers make use of double extortion tactics which involve not only encrypting data, but also saving a copy of it and threatening to publish it for everyone to see. Ransomware 3.0 makes it very hard to rescue any data by using modern encryption methods.

2.4.2 Cybersecurity measures

To keep up with the ever evolving threat landscape, small and medium-sized enterprises (SMEs) should implement a layered portfolio of procedures, technologies, and policy-level measures. These can be grouped into four categories:

1. Real-Time Monitoring & Cyber Resilience
2. Secure Configuration & Zero-Trust Architecture
3. Human-centric Defenses & Awareness
4. National & Industry-Level Coordination

I. Real-Time Monitoring and Cyber Resilience

Security Information and Event Management (SIEM): SIEM platforms collect logs from firewalls, servers, applications, and endpoints, and apply custom detection rules and analytics to anomalies — such as unusual login patterns or bulk data transfers that may indicate compromise [28].

Intrusion Detection/Prevention Systems (IDS/IPS): Network- and host-based IDS/IPS continuously inspect traffic for known indicators of compromise (IoCs). These systems are able to block or quarantine malicious payloads before they reach critical assets [28].

Automated Patch Management: Automated tools ensure that operating systems, applications, and firmware remain up to date with published patches, reducing exposure to known vulnerabilities before threat actors can exploit them [29].

Backup & Disaster Recovery Planning: Regular backups stored on air-gapped servers, along with documented restoration procedures, make up the last line of defense. This enables rapid recovery in the event of ransomware or large-scale disruptions.

II. Secure Configuration and Zero-Trust Architecture

A zero-trust approach treats every user, device, and network as untrusted by default. Key attributes of a zero-trust architecture include least privilege, micro-segmentation, and continuous verification of identity and device posture. Adherence to NIST ensures that access decisions are context-aware, significantly raising the bar for privilege escalation [30].

III. Human-Centric Defences and Awareness

Building on digital hygiene best practices (see Section 2.1), organizations should implement technical controls with employee training in phishing awareness, secure password management, and incident reporting procedures. Regular simulated phishing campaigns help reinforce vigilance and identify high-risk behaviors that require further attention.

IV. National and Industry-Level Coordination

Participation in national cybersecurity programs and information-sharing initiatives help SMEs stay informed of emerging threats and compliance requirements. Regulations, incident reporting obligations, and shared threat intelligence drive collective resilience across sectors.

2.5 Related works

Over the past years, researchers have increasingly turned to Metasploitable 3 as a benchmark for penetration testing and vulnerability analysis. Karagiannis et al. (2024) presented Shennina, an AI-driven framework that systematically probes an instance of Metasploitable 3 (Ubuntu) [31]. This automatic way of penetration testing allowed mapping each discovered weakness to MITRE ATT&CK tactics. Shennina is driven by a rule-based approach and demonstrated how known exploits found in common services, such as Tomcat and SSH, could automatically be detected and validated in a secure and isolated environment. In addition to this research, Moreno et al. (2025) applied a reinforcement-learning agent paired with a transformer-based Q&A recommender to the same instance of Metasploitable 3, allowing the system to both identify and prioritize chain exploits [32]. This involves leveraging Jenkins or Tomcat vulnerabilities for example. Whereas Karagiannis et al. relied on predefined rules for their AI-driven framework, Moreno et al. presented a self-learning model that can discover sequences of potential attack steps over time. This solution is an evolving understanding of the attack surface and could effectively optimize paths without human intervention.

Complementing these AI-driven studies, other researchers have focused on quantifying real-world exploit risk and surveying the larger penetration testing tools. Yoon et al. (2023) bridged vulnerability scanning with hands-on exploitation by using the Metasploit framework to confirm the risks presented in specific CVEs [33]. This was conducted by deploying exploit modules against their targets and produced a risk score that ranks vulnerabilities according to their actual exploitability rather than their theoretical severity. From another perspective, Alhamed and Rahman (2023) conducted a systematic literature review of penetration-testing methods and tools that ranged from initial reconnaissance with Nmap, web application tests with Burp Suite and post-exploit activities with the Metasploit Framework [34]. They concluded practices and remediation strategies without performing new lab experiments. The former study quantifies threats through direct attack, while this offers a wider insight into tool-chains and procedural frameworks.

Regarding the organizational perspective of cybersecurity, two papers address how small and medium-sized enterprises (SMEs) can adopt effective security measures, even with limited resources. El-Hajj and Mirza (2024) proposed a lightweight solution consisting of a simple risk-assessment framework that's tailored to SMEs [1]. It involves mapping common vulnerabilities to NIST and ISO standards and recommending prioritized mitigation steps that fit tight budgets and lean IT teams. In parallel, Armoogum et al. (2025) conducted a survey on workplace digital hygiene practices [35]. The research included patch management, authentication policies, backup management and employee training. Data from this was compiled into top ten behaviours that mitigate common attack vectors. El-Hajj and Mirza delivered a structured tool for SME risk assessments and Armoogum et al. [35] emphasized human habits and organizational routines as the frontline defense against cybercrime.

2.6 Research Gap

Despite the valuable contributions from the related works, none of these studies fully align with theory, lab practice and SME reality in one cohesive study. There is no work that integrates a systematic literature review with hands-on experimentation on Metasploitable 3 (Ubuntu). Although some AI and reinforcement-learning approaches present multi-step attacks, there is no in-depth analysis of how a vulnerability can lead to internal compromises of a realistic SME network environment. Established threat-modeling frameworks (such as STRIDE or MITRE ATT&CK) are rarely applied directly to categorize and prioritize the vulnerabilities uncovered in these lab environments. While digital hygiene topics in the gathered studies, they only review best practices and do not go further into how they can affect mitigation and the severity of compromise using hands-on experimentation with an environment such as the one Metasploitable 3 offers. Proposed mitigations were rarely tested for realistic SME constraints: limited budgets, legacy infrastructure and minimal security teams.

3 Method

This section outlines the methodological approach used in this study to investigate common vulnerabilities in a sandboxed environment and how they can be mitigated. The study utilizes a mixed-method approach consisting of a systematic literature review and a hands-on experimentation in a controlled environment using the Metasploitable 3 Ubuntu machine. The goal is to gain theoretical understanding and empirically validate how common vulnerabilities can be identified and exploited using real-world tools. This method was chosen to ensure both academic and practical relevance, and to mimic the kind of assessments often led by security professionals.

3.1 Research Design

The Systematic Literature Review (SLR) is used to understand best practices in vulnerability assessment, threat modeling, mitigation, and real-world breaches. The research papers are sourced from academic databases, such as IEEE Xplore, Google Scholar, ACM, and Scopus. The SLR aided in defining experiment steps and categorizing identified vulnerabilities.

The Experimentation component was carried out in a sandboxed network with a Kali Linux machine as the attacker and a Metasploitable 3 Ubuntu as the target machine. It followed a typical testing workflow: recon → exploit → post-exploit. Tools that were used include Nmap, Metasploit, and SQLMap.

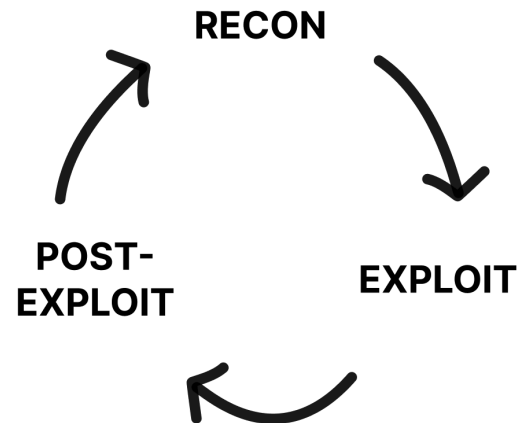


Fig 1. A visual representation of testing workflow.

This design was selected to provide reproducible, realistic, and educational results. It further allowed the results to be directly mapped to real-world cybersecurity challenges, especially in SME settings.

3.2 Systematic Literature Review Process

The systematic literature review (SLR) process implemented in this study was designed to ensure a comprehensive, unbiased, and reproducible collection of relevant academic material in the field of cybersecurity. The process is structured into several key stages: selection of databases, formulation of keywords and queries, an initial review of literature, complete screening, and the evaluation of material and findings.

3.2.1 Databases

A curated selection of academic databases was chosen as the primary sources for gathering literature. These include IEEE Xplore, Google Scholar, ACM, and Scopus but also relevant tool documentation and press releases. Each database was selected for its comprehensive repository of peer-reviewed articles, conference papers, and technical reports. This multi-database approach was adopted to ensure extensive coverage of interdisciplinary research topics related to cybersecurity, data breaches, and data integrity. By accessing both multidisciplinary and domain-specific sources, the review aimed to capture the full spectrum of contemporary research in the field.

3.2.2 Keywords and Queries

To efficiently navigate the vast array of available literature, a targeted set of keywords was developed in alignment with the research objectives. Core terms included "cybersecurity", "data breaches", "data integrity", "information security", "risk assessment", and "vulnerability management". These keywords were strategically combined using Boolean operators (AND, OR, NOT) to form precise search queries. For instance, searches were executed using combinations such as "cybersecurity AND data breaches" and "information security OR data integrity NOT obsolete". This methodological use of Boolean logic served

to refine the search results, enabling the exclusion of irrelevant material and ensuring that only the most pertinent studies were considered.

3.2.3 Selection strategy

The first review stage involved a rapid screening of the retrieved literature by examining titles, abstracts, and keywords. This step was critical for determining the relevance of each study to the overarching research questions. Articles that clearly fell outside the scope of the study were discarded at this stage. Conversely, studies that appeared to align with the inclusion criteria were earmarked for further evaluation. This preliminary filtering not only streamlined the subsequent review process but also ensured that the literature pool was manageable and focused.

3.2.4 Complete Screening

Building on the initial review, a complete screening was then performed. In this phase, the full texts of the shortlisted studies were carefully analyzed against a set of predefined inclusion and exclusion criteria. Factors such as publication date, research methodology, study context, and the quality of the reported findings were critically evaluated. The complete screening process ensured that only studies with rigorous methodological approaches and high relevance were retained for further analysis. Studies failing to meet these standards were systematically excluded, thereby enhancing the overall quality and reliability of the literature review.

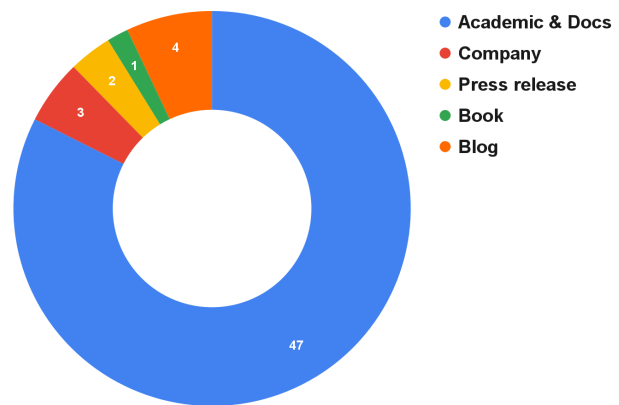


Fig 2. A Pie Chart of used sources categorized by type.

After applying the inclusion and exclusion criteria, a total of 57 sources were chosen to provide a solid foundation of knowledge for this study. 47 of the selected sources were academic papers, books and technical tool documentation, this accounted for ~84% of the total. The remaining ~16% consisted of company websites, press releases and blog posts.

3.2.5 Evaluation of Material and Findings

The final phase involved an in-depth evaluation of the selected material and the synthesis of findings. Each study was appraised based on its methodological robustness, the credibility of the results, and its contribution to the body of knowledge in cybersecurity. Special attention was given to the trustworthiness of the sources, the transparency of the research design, and the consistency of the reported outcomes. Comparative analyses were performed to identify recurring themes, significant discrepancies, and potential research gaps. Additionally, the limitations of individual studies were documented to provide context for the findings. This critical evaluation not only validated the relevance of the literature but also guided the interpretation of results and the identification of avenues for future research.

Overall, the systematic literature review process was meticulously designed to ensure a balanced and thorough investigation of the current research landscape in cybersecurity. By integrating a multi-database search strategy with rigorous screening and evaluation criteria, this approach lays a strong foundation for drawing meaningful and reliable conclusions.

3.3 Tools, Technologies and Data Collection

In order to successfully discover and analyze vulnerabilities within a Metasploitable environment, one must use a diverse set of tools and technologies throughout the penetration testing process. These tools are categorized based on their functions: reconnaissance and scanning, exploitation, and data collection. The application of these tools is critical both for simulating real-world attacks, but also to provide robust and replicable data.

3.3.1 Penetration Testing Environment

When performing penetration testing on a machine or network, the environment of the attacker machine's environment plays an important role. This is especially important when targeting a machine that is known for being vulnerable, such as Metasploitable. In order for the entire lifecycle of the penetration testing and vulnerability assessment to be performed in an effective and secure way, the attacker's environment needs to be isolated, controlled and stable.

The chosen environment for this study is Kali Linux [36]. Kali Linux is a linux-based operating system, specially designed for penetration testing and security assessments. It comes preinstalled with powerful tools such as nmap, OpenVAS, Metasploit and other security tools. This makes it an ideal environment for comprehensive penetration testing and security assessment.

In order to isolate the testing environment, virtualization is used to host the Kali Linux machine. This provides an isolated environment for safe simulation of attacks against Metasploitable 3 machines without compromising the testers' host systems. Depending on the host machines' operating systems, different kinds of virtualization software are available in order to meet the testers' needs of secure virtualization of Kali Linux. This study utilizes two host systems, one running Arch Linux and the other one running macOS.

3.3.2 Reconnaissance & Scanning tools

Tools in this category are used for network mapping, port scanning and service detection. For example, **nmap** is used for its advanced capabilities in detection and identification of Operating Systems, open ports, service names and versions as well as script scanning [37]. This allows for detailed mapping of a target system.

Once open ports and running services on the system are identified, another tool is used for further vulnerability assessment. This tool is called OpenVAS [38]. Unlike nmap, which maps a network and identifies its components, OpenVAS serves as the next step in the reconnaissance phase, namely vulnerability assessment. It is an automated vulnerability scanner that takes the services discovered by nmap as input and assesses them for known vulnerabilities, configuration issues and missing patches. When proceeding with this kind of workflow, it is crucial to start with a tool like nmap before progressing to a tool like OpenVAS. The reason for this is that depending on the operating system of the target device, OpenVAS scans should be tailored accordingly to be able to discover and generate the most relevant and reliable data on OS-specific vulnerabilities. Nmap fulfills this need, as it not only scans and detects open ports and running service information, but it also performs OS fingerprinting, which means that it gains insight into the operating system.

3.3.3 Attacking tools

I. SQLMap

SQLMap is an open source CLI tool used to automate the identification and exploitation of SQL Injection vulnerabilities and compromising database servers [25]. It allows for data fetching, accessing the underlying operating system and executing commands on the host system over a remote connection.

II. Metasploit Framework

The Metasploit Framework is an open source platform for penetration testing that was founded by H.D. Moore in 2003 [39], [40]. The project began as a portable network tool originally written in Perl, housing a collection of exploits for various types of systems. By 2007, it had been rewritten in Ruby and evolved to a very powerful and modular framework that provided great opportunities for scaling and maintainability. At this point in time, The Metasploit Framework was quickly becoming the main tool in use of any penetration testing activities. Its modular design not only allowed for easy integration with custom made exploits and payloads, it also ignited a new, curious and spirited community of developers, researchers and security experts who continuously contributed to the framework's evolution.

In 2009, the project was acquired by Rapid7 [41]. This acquisition led to the commercialization of the framework, a significant milestone in its evolution, resulting in better support, broader community and further development. Today, the framework is present in every educational guide and course on cybersecurity and ethical penetration testing [42], [43].

The installation process of the Metasploit Framework depends on what operating system the attacking machine is using [44]. Some distributions of Linux, such as Kali Linux, come with Metasploit pre-installed and configured. Users can find instructions for installing it on other operating systems via the GitHub repository where most major operating systems are listed as supporting running the Metasploit Framework.

The Metasploit Framework has a variety of purposes, but is mainly used for penetration testing, vulnerability assessments and exploit development [45]. The tool will contribute towards producing an analysis and assessment for this study by testing different kinds of attacks and exploits that are potentially present in the Metasploitable Environment. Some of its unique features include automation and easy integration into other tools but also Meterpreter which gives the user access to an interactive reverse-shell on the victim machine [46], [47].

3.4 Experimental Setup: Metasploitable Environment

The experiment of this study entails a controlled environment consisting of two virtual machines. These consist of an attacker machine (running Kali Linux) and a target machine (running Metasploitable 3 Ubuntu). The purpose of emulating an attacker in a controlled virtual machine is twofold — it comes prepacked with reconnaissance tools and attack tools, and it is isolated from the host machine for safety. The purpose of the target virtual machine is to mimic a generic vulnerable system that may be explored and exploited without affecting the host system or crossing ethical boundaries.

3.4.1 Metasploitable 3

The Metasploitable machines are virtualized (often Linux based) operating systems, designed and preloaded with many vulnerabilities commonly found in computer systems. The community **Rapid7** are behind the creation and maintenance of these machines and currently there are three versions [48].

The Metasploitable machines are virtual machines that are purposely built and designed with vulnerabilities in the system [49], [50]. In addition to providing a solid testing ground for penetration techniques, the machines also serve the purpose of providing a safe and controlled environment for exploring common vulnerabilities found in production-like environments, without risking an actual production environment. The intentionally vulnerable design includes flaws like unpatched software and misconfigurations to reflect real-world scenarios and allows for a very hands-on learning experience compared to traditional learning methods [51], [52].

The latest version of Metasploitable: Metasploitable 3 comes in two flavours: Windows Server 2008 R2 and Ubuntu Server 14.04. The Windows Server variant offers vulnerabilities specific to Windows environments where vulnerabilities and misconfigurations exist within Windows services, Internet Information Services (IIS) and other Microsoft software [53]. The Windows Server variant of Metasploitable 3 reflects a typical Windows-based environment.

3.4.2 Virtualization & Emulation Setup

To conduct the experimentation and penetration testing for the vulnerability research in this study, virtual machines were set up on two separate host systems. This allowed for both researchers to easily distribute the tasks and tests efficiently. One host system was running a Linux-based operating system while the other was running macOS on Apple Silicon. Both hosts had two identical virtual machines installed: Kali Linux, which was used as the attacker's system and Metasploitable 3 (Ubuntu) as the vulnerable target system. The goal across both platforms was to ensure a secure and isolated environment for testing different exploits and vulnerabilities.

The general structure of the environment setups were consistent with each other but differed in which tools and utilities were used for the installation procedures to accommodate the different platform and architecture constraints. The Linux host utilized KVM, QEMU and libvirt which is a common stack for Linux-based virtualization [54], [55]. This offered near-native performance and some advanced virtualization management features.

KVM is a hardware virtualization solution baked into the Linux kernel that includes virtualization infrastructure and extensions for Intel and AMD processors. KVM allows for running multiple virtual machines, each one with private virtualized hardware. QEMU is an open source software emulation and virtualization solution. The reasoning behind using QEMU and KVM in combination is that KVM gives QEMU access to the host system's hardware, which accelerates performance and provides a near-native experience. On top of using KVM/QEMU, a package called libvirt was also used [56].

As for the macOS host, the virtualization setup relied on UTM, a QEMU-based virtualization tool that works with Apple Silicon [57]. Kali Linux offers an ARM-compatible image which is perfect for the Apple Silicon system architecture but the Metasploitable 3 image was only offered in a VMDK format. Luckily, the image was possible to compile into a QCOW2 file that made it compatible with UTM. This was done through the QEMU CLI tool.

4 Results

This section covers the results of the exploit testing conducted in this study, all of which were carried out in the previously defined isolated Kali + Metasploitable3 setup (see Section 3.4). The experimentation led to the discovery of:

- 9 open TCP services,
- 7 of which were running versions known to be vulnerable,
- and 1 web application (the payroll app) susceptible to SQL injection.

These findings exposed five high-risk attack vectors:

- Unauthorized database login
- SQL Injection
- Remote Code Execution in Drupal
- Exposed admin interfaces
- Credential reuse

These attack vectors allowed a full compromise from a single entry point. In the following subsections this study (Section 4.1) enumerates the services, (Section 4.2) shows how each service was exploited, (Section 4.3) categorizes the threats and vulnerabilities, and (Section 4.4) analyzes potential impact and performs risk assessments.

4.1 Identification of Vulnerabilities in the Metasploitable Environment

An initial Nmap scan of commonly open ports and services revealed these ports to be open:

Table 1. Open ports and service versions discovered in the Metasploitable 3 (Ubuntu 14.04) environment

PORT / protocol	Service	Version
21 / TCP	ftp	ProFTPD 1.3.5
22 / TCP	ssh	OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80 / TCP	HTTP	Apache httpd v.2.4.7
445 / TCP	netbios-ssn	Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631 / TCP	ipp	CUPS 1.7
3306 / TCP	mysql	MySQL (unauthorized)
3500 / TCP	http	WEBrick httpd 1.3.1 (Ruby 2.3.8 (2018-10-18))
6697 / TCP	ircs-u	UnrealIRCd
8080 / TCP	http	Jetty 8.1.7.v20120910

Table 1 shows the open ports available on the Metasploitable 3 machine, as well as the versions of their respective services. This first step of scanning ports mimics the properties of a realistic scenario where a threat actor would run scans on a target's ip address to gather information about a system and potentially be able to exploit open ports and/or outdated services. These exposed services guided the next step — targeted exploitation of critical entry points.

4.2 Exploitation of Vulnerabilities

The HTTP port (80) of the system acted as an endpoint to discover more attack surfaces, including web applications. Accessing this port via a browser from the attacker machine revealed several web applications that could be assessed and potentially exploited. These applications, as well as accumulated attack surface, is documented below:

4.2.1 Payroll App

Among the web applications was a payroll application. After some probing it became apparent that this application was susceptible to SQL injection attacks. By entering a simple SQL Injection query in the password field on the login page of the app, it was possible to log in without correct credentials. A successful login revealed sensitive data about users, such as their salaries, as well as all users' login credentials for the payroll app.

```
kali@kali$ cat users.csv
salary,password,username,last_name,first_name
9560,help_me_obiwan,leia_organa,Organa,Leia
1080,like_my_father_beforeme,luke_skywalker,Skywalker,Luke
1200,nerf_herder,han_solo,Solo,Han
22222,b00p_b33p,artoo_detoo,Detoo,Artoo
3200,Pr0t0c07,c_three_pio,Threepio,C
10000,thats_no_m00n,ben_kenobi,Kenobi,Ben
6666,Dark_syD3,darth_vader,Vader,Darth
1025,but_master:(,anakin_skywalker,Skywalker,Anakin
2048,mesah_p@ssw0rd,jarjar_binks,Binks,Jar-Jar
40000,@dm1n1str8r,lando_calrissian,Calrissian,Lando
20000,mandalorian1,boba_fett,Fett,Boba
65000,my_kind_a_skum,jabba_hutt,Hutt,Jaba
50000,hanSh0tF1rst,greedo,Rodian,Greedo
4500,rwaaaaawr8,chewbacca,<blank>,Chewbacca
6667,Daddy_Issues2,kylo_ren,Ren,Kylo
```

Fig 3. Output from the database containing credentials, salaries and personal info

These newly found credentials were also confirmed to be identical to the credentials for the underlying Metasploitable 3 Ubuntu system. Hence, it was now possible to directly connect to the system via ssh, logging in with any user's credentials.

4.2.2 SSH

Having access to an ssh connection made it possible to further map out the system and perform exploits from an internal standpoint. The user *leia_organa* was chosen as an initial target to further explore the system. Upon establishing a connection, the registered users' permissions and privileges were mapped out by executing the *groups* command for each user, which returns what unix groups a specific user is part of. Upon confirming the groups that these users were part of, several users were confirmed to be part of the sudo group, which allowed for sudo access to the system.

It was now possible to navigate to */var/www/html/*, and explore the internals of the web applications running on the machine. By listing out the files and directories in this directory using the **ls** command, a file of interest was found, namely "payroll_app.php". This file was then read using the **cat** command, revealing the root credentials that the app uses to connect to the MySQL database server.

4.2.3 MySQL

Having retrieved the credentials that the PHP app uses to establish a connection to the MySQL database server made it possible to connect to the database server via the `mysql` command, over an `ssh` connection — gaining root privileges. This allowed for viewing all data present in the database, modifying the data, creating new tables, and deleting data.

To explore different entry points and properly identify as much attack surface as possible, an `sqlmap` command was run from the attacker machine:

```
sqlmap -r req.txt -dbms="MySQL" -level=1 -risk=1 -dump  
-output-dir=output -batch
```

The output of this command was a `csv` file, containing all users' salaries and credentials to the database. This was hence identified to be yet another entry point to access the database credentials, bypassing the need to perform an SQL Injection attack on the payroll app. This tool did not only reveal what was seen via the `gui`, but also the entire table.

4.2.4 Docker

Several users were confirmed to be part of a `docker` group, which indicates further attack surface. Using `ssh` to connect to the system using a user in the `docker` group allowed for exploration of `docker` containers and images on the system.

4.2.5 Drupal

Drupal is a content management service, and the initial `nmap` scan revealed that the target machine was running an outdated version that was susceptible to CVE-2014-3704. Conveniently, the `metasploit` framework offered a script that leveraged necessary `php` injections in order to exploit this vulnerability. By simply choosing the exploit in `Metasploit`, setting up attack variables such as the target machine's IP address, and running it, a reverse shell was obtained. This bypassed the need for any authentication or necessary credentials.

Within the reverse shell, a simple `cat` command of the payroll app quickly displayed the login credentials for the `mysql` server, which as previously mentioned turned out to be the same credentials for the underlying `Metasploitable 3` `Ubuntu` machine.

Having a reverse shell connection, just like being able to connect via `ssh`, made it possible to compromise the whole system. With this kind of access, one could install malware, keyloggers, and even ransomware which would lock down the whole system.

4.2.6 FTP

The initial `nmap` scan of the `Metasploitable 3` system from the `Kali` machine shows that the `ftp` service was available via the open 21 port. This revealed the possibility to connect to the system via the `ftp` command with user credentials that were obtained previously. It was then possible, much like with the `ssh` connection, to explore the file system and find credentials, configurations and other sensitive data.

4.3 Categorization of Threats Using Established Threat Modeling Frameworks

The STRIDE framework can be used to label each identified threat with a type. Beneath is a table that shows an overview of what STRIDE type each threat is considered to be in this scenario.

Table 2. Categorization of threats in the Metasploitable 3 (Ubuntu 14.04) environment using STRIDE

THREAT	STRIDE TYPE	REASONING
SQL Injection in Payroll App	Tampering, Information Disclosure, Elevation of Privilege	Tampering <i>Modifies query logic to bypass authentication.</i> Information Disclosure <i>Extract user salaries and credentials.</i> Elevation of Privilege <i>Gained valid system credentials.</i>
Unauthorized MySQL Access	Tampering, Elevation of Privilege	Tampering <i>Direct modification access to the database.</i> Elevation of Privilege <i>Root-level database access.</i>
Drupal (CVE-2014-3704)	Tampering, Elevation of Privilege	Tampering <i>Executes malicious PHP payloads to the server.</i> Elevation of Privilege <i>Full reverse shell on the system.</i>
SSH & Credential reuse across multiple services on the system (Docker, FTP)	Spoofing, Elevation of Privilege	Spoofing <i>Attacker presents valid root credentials (acquired from SQL Injection in Payroll App).</i> Tampering <i>Full and unrestricted access to the entire system, is able to modify users and permissions.</i>

The most predominant type was Elevation of Privilege where in all identified threats of the penetration testing made it possible to gain stronger leverage. This was made possible by the leaked credentials from the Payroll App which seem to be reused throughout the entire system.

4.4 Impact Analysis and Risk Assessment

The vulnerabilities uncovered in the Metasploitable 3 environment illustrate how an attacker can leverage a single weakness into a full system compromise. In this particular exploit chain, the SQL Injection in the Payroll App presented an initial attack surface and acted as the main foothold which allowed the attacker to successfully read all user credentials. Because those same credentials were reused across all services, the attacker never got stopped by any further authentication.

This chain of compromise presents a high-impact scenario that is very easy to exploit whenever bad digital hygiene practices like credential reuse are combined with unpatched and publicly exposed services.

In the perspective of the potential impact this could have on an environment like this, successful exploitation could lead to enabling a malicious actor to:

- 1. Steal or tamper with sensitive data**
Salary records, configuration files, database contents, emails, etc.
- 2. Deploy malicious code**
Backdoors, rootkits, malware, ransomware, etc.
- 3. Disrupt operations and availability**
Locking out real users, corrupting data or system components, etc.

These risks and the exploit chain illustrate an extremely aggressive and available attack surface. The exploit chain shows how when one vulnerability is exploited, others fall in succession.

5 Mitigation Strategies

This section presents an implementation of the proposed mitigations for the discovered vulnerabilities. After having identified and prioritized the high-risk vulnerabilities in the Metasploitable 3 (Ubuntu) environment an approach for improving system resilience and breaking the attack chains was developed.

5.1 Proposed Mitigation Strategy

Building on the vulnerabilities discovered in Section 4, a mitigation strategy can be defined and tailored to the situation. The solution involves both passive and active precautions that allow the system to be protected against the exploits demonstrated.

A robust patch management process is the most important aspect of this approach. By automating updates and enforcing the installation of security fixes, administrators will no longer depend on manual intervention to keep every component up to date. This means integrating a centralized patch management tool that routinely checks for updates and applies them to ensure a secure operating system, services, web servers and more.

The other equally important aspect of this mitigation strategy is enforced good practices in digital hygiene and strengthened authentication across the entire system. As proved in the experimentation, a single SQL injection quickly revealed passwords for every user on the system. These passwords were reused throughout every service and allowed for unauthorized access to the root system.

At the application layer, input validation is the primary defense against SQL injections. In addition to this, all database queries should be written using parameterized statements or stored procedures, ensuring that the input provided by a user is never interpreted as executable code.

Lastly, network segmentation and port reduction are often seen as best practices but in this context, where a single server hosts multiple services, it cannot be implemented. In addition, a focus on continuous monitoring is strongly advised. This can be done by deploying intrusion detection and prevention systems that monitor the system and network for suspicious behaviours in real time. Alerts from this can then be used to notify administrators and security teams.

By combining these aspects of the mitigation strategy, multiple layers of defense become overlapping of each other. This means that even if one fails, the others will detect and cover for it before any attack can fully unfold.

5.2 Implementation and Evaluation of Mitigation Measures

To mitigate the attack chain that was discovered during the experimentation with the Metasploitable 3 (Ubuntu) machine the following measures were successfully implemented and evaluated.

The first measure that was taken was to upgrade the identified services that proved to be vulnerable. This includes the Drupal service, which as previously mentioned acted as the entry point for the most critical attack chain. By upgrading the Drupal service, the CVE-2014-3704 vulnerability was patched, and it was no longer possible to exploit it using readily available payloads.

Another mitigation measure that was enforced was to update credentials for the various users of the system, both in individual services, as well as the underlying Ubuntu system. This was yet another step to reduce the impact that one single attack chain entailed. Attackers would now need to extract credentials by other means, such as password cracking or brute-force attacks, which is significantly more time-consuming and complex. This applied not only to regular users, but also to administrator and root accounts.

These measures successfully eliminated threats 2-4 that were listed in the table in Section 4.3.

6 Discussion and Limitations

The goal of this study was to answer the established research questions:

1. How can vulnerabilities found in a Metasploitable Environment relate to the real world?
2. How can common vulnerabilities be mitigated?

Through the experimentation phase, the target machine was successfully compromised. Several vulnerabilities were identified and exploited, revealing several attack chains. Among the found vulnerabilities, one vulnerability proved to be an entry point for a full chain of compromise that avoided the need for complex attacks to access each service. This vulnerability was the open port running Drupal, a content management service used to create, structure, and update content on web applications. The particular version of Drupal that was susceptible to the CVE-2014-3704 vulnerability. A simple exploit from the attacker machine, leveraging Metasploit and its library of payloads, allowed for a Remote Code Execution attack, resulting in the acquisition of a reverse shell on the target system. This attack chain, along with other exploits that were performed, stressed the importance of secure practices in order to protect a system from threat actors.

This section will explore an analysis of real-world breaches and their ethical implications, the implications of the experiment, its relation to real-world systems (particularly SMEs), policy implications and recommendations for digital hygiene, and the limitations of this study.

6.1 Analysis of Real-World Breaches and Ethical Implications

Both security incidents examined in Section 2.3 (Colonial Pipeline and Coop & Kaseya) illustrate how simple flaws can disrupt entire operations and that incidents like this can lead to devastating consequences for organizations. These cases raise important ethical concerns on the topic of victim response and attacker motives.

6.1.1 Poor Digital Hygiene & Credential Management

In the Colonial Pipeline breach, attackers leveraged leaked VPN credentials to gain initial access, they then started to move across the entire network, escalating privileges and then finally deploying their ransomware. The root cause was weak digital hygiene in terms of properly managing system credentials. These credentials were reused and allowed the attackers unrestricted access to critical OT infrastructure. Colonial Pipeline's decision to pay the 4.4 million USD ransom did successfully restore their operations but generated public debate revolving around the ethics of this.

Colonial Pipeline had to make a big decision, risk leaving households and businesses without gas and heating or risk paying the ransom fee and hope that their systems get restored. Paying such ransoms can incentivize further attacks and fund criminal enterprises which do not benefit the society.

The security revolving around properly managing credentials for such important infrastructure as in the case of Colonial Pipeline could be improved by implementing preventative measures with digital hygiene in mind. This could for example be making sure that unused credentials are deactivated, the implementation of multi-factor authentication and a security team that looks out for any organizational data leaked publicly.

6.1.2 Patch management and supply-chain risks

The Coop & Kaseya incident presents how weaknesses in supply-chain security, bad configuration and patch management can be leveraged into a complete stop of operations. In this case, the attackers were able to deploy their ransomware via unpatched vulnerabilities and forged HTTP requests against the Kaseya VSA software. This allowed them to remotely update systems and deploy ransomware disguised as a regular patch update.

This exploit became possible because of an overly trusting network architecture. Similarly to the Colonial Pipeline incident, a lack of multi-factor authentication was present amongst other missing authentication features that could verify allowed users and permissions.

In contrast to the previously mentioned incident, Coop refused to negotiate with the attackers. Instead, Coop immediately shut down all of their operations and deployed IT technicians to reinstall and secure each system manually by relying on verified backups and established restoration procedures. This did not happen overnight and while the restoration was in progress, the supermarket chain collaborated with industry peers and help-organizations to minimize food waste during the outage. Coop's refusal to pay the ransom demonstrated the value of backups and established recovery procedures are essential for handling an incident as a widespread ransomware attack. They were able to fully recover without incentivizing further attacks and funding future attempts.

6.2 Policy Implications and Recommendations for Digital Hygiene

The results of the experiments conducted in this study (Section 4-4.2), in combination with the threat modelling of the found vulnerabilities (Section 4.3), and the identification of a critical attack chain (Section 4.4), reflect a very real issue for a lot of SMEs. It has become apparent that a vulnerability does not necessarily exist in isolation, and that without continuous monitoring and patch management, one vulnerability can be the cause of system compromise, leaked sensitive data, and financial loss. This stresses the need for a solution which is based on the fundamental knowledge of how vulnerabilities appear and how to manage them. This section outlines a general proposition for policy implications and recommendations for system maintenance, as well as how to approach the issue of digital hygiene.

6.2.1 Implications for Security Policy

As shown in Section 5.2, a crucial step to mitigate existing vulnerabilities and prevent future ones is the practice of continuously upgrading services and packages in digital systems. CVE's are not only records of old vulnerabilities, but are continuously emerging. A particular version of a service can be safe to use, only to be susceptible to new-found threats a while later. To keep a system secure does not only equate to relying on security professionals to perform vulnerability assessments and penetration tests. A fundamental step that businesses can enforce without the need for such specialized actions is to implement a robust regimen for upgrading services.

Vendors of business-centric services continuously evaluate and monitor the structure of their services, and hence continuously release new updates containing patches to new-found vulnerabilities. This highlights a crucial reason why outdated packages are particularly vulnerable. Not only do they contain vulnerabilities that have not been patched, but those vulnerabilities are publicly documented and are hence at the disposal of threat actors that are easily able to take advantage. Thus, this study proposes that SMEs enforce regular upgrades of their services and stay updated on when new patches are released.

An additional security issue that does not get automatically fixed by upgrading packages is input validation, specifically for databases. As shown in the experimentation phase, the target system suffered from an SQL Injection vulnerability. This type of vulnerability does not necessarily arise from use of outdated services, rather its source is often implementation. Thus, this study suggests that SMEs ensure that their database implementation, and any other implementation of authentication solutions, are following best-practices to reduce the risk of compromise by injection of malicious SQL queries.

6.2.2 Recommendations for Digital Hygiene

Following technical practices for monitoring and updating system components is the first step. However, attackers do not only exploit systems that are technically outdated or faulty — the most critical vulnerabilities are oftentimes human. There is an important observation to be made on the critical attack chain identified in this study's experimentation phase (Section 4.4), of which the outdated Drupal service served as an entry point. A factor that allowed this attack chain to be particularly compromising is that root credentials and user credentials were reused across the entire system. Had it not been for the fact that the credentials that were discovered by exploiting the MySQL database were the exact same credentials to the underlying system, it would have been an exceedingly more time-consuming and complex effort to be able to compromise the entire system. Had the credentials been different across different services, attackers would need to get ahold of those credentials by e.g. password cracking, which is not only considerably more time consuming, but also more complex.

This study proposes that in addition to technical policies, SMEs should invest in educating employees on how to maintain digital hygiene. This includes using different passwords for each service, updating passwords frequently, and storing passwords in secure ways. A common reason that users of digital

systems reuse credentials is that it becomes difficult to remember them. This is also a common reason for using easy, and hence predictable passwords. Implementing a rigid credential policy is however not the last step to ensure safe handling of credentials. Users also need a secure way to store them. By mandating the use of reputable password managers, one can avoid vulnerable storage of credentials.

The educational part of this proposition does not only benefit the practices and behaviors of users when interacting with the systems. It also serves to raise the security awareness regarding other types of social attacks. One such attack that is prevalent is phishing emails. If businesses invest in education and security awareness of employees, the risk of system compromise by social engineering such as phishing attacks are drastically reduced.

6.3 Limitations of the Study

While the controlled lab experiments illustrated clear vulnerabilities, exploit chains and demonstrated potential solutions for mitigations, they would be stopped short of representing the true and dynamic testing that occurs in real situations. The experiment represents only a single static snapshot of the Metasploitable 3 (Ubuntu) machine. This means that there is only one service configuration, one set of initial credentials, one image of the operating system, etc. This does not reflect a realistic representation of a real system found in real environments since they do undergo update processes, configuration changes and shifting patterns in usage. The controlled lab also did not factor the many layers that can be found in real SME environments such as hardware firewalls, VPN gateways, container orchestration, cloud APIs and the unpredictable workflows of actual users. When factored together, these constraints limit the ability to quantify how well the proposed mitigation could withstand sustained and complex attacks that are ever evolving.

The systematic literature review conducted in this thesis is based on best practices, such as using multiple databases and boolean search strings. However, it was limited by access and language. The access of essential industry reports is often restricted by means of paywalls, and non-English research was excluded. The range of release dates for the articles used in this study reaches its end in April 2025, which means that any emerging academic frameworks published after this date are hence excluded from the scope. Areas such as AI-driven threat discovery and zero-trust architectures are rapidly evolving. Consequently, even a month can lead to significant new techniques that would substantially improve the threat modelling and mitigation recommendations in this study.

As this project was conducted over a single semester with a team of two, the project naturally faced limitations in finite time and resources. This meant that broadening experiments to multiple attacks, service versions and operating system versions was not possible. Similarly, testing under load and testing brute-force methods was also not possible. In addition to this, the term “SME” was treated as an umbrella term, but for instance a tech startup with cloud microservices would have a very different attack surface and compliance rules than a family-run retail store running on Windows servers. Finally, this study did not engage in investigating real end users by for example doing password-reuse surveys, simulated phishing attacks and usability testing of proposed admin workflows. Human behaviour is unpredictable and it would require more investigation into how individuals could adopt and learn about digital hygiene without trying to resist or work around them in real work situations.

7 Conclusion

This study investigated how vulnerabilities discovered in a controlled Metasploitable 3 (Ubuntu) environment relate to real-world SME systems (RQ 1) and how such vulnerabilities can be mitigated (RQ 2). Through a combination of a systematic literature review and hands-on experimentation, a total of five high-risk attack vectors have been identified: SQL Injection in Payroll app, unauthorized MySQL access, Drupal exploit (CVE-2014-3704), exposed admin interfaces (SSH, FTP, Docker, etc.) and credential reuse. These vulnerabilities allowed an attacker to progress from a single foothold in the system to full system compromise.

RQ 1: The vulnerabilities uncovered in the Metasploitable 3 lab represent the real landscape of cybersecurity incidents occurring all over the world. An initial SQL Injection flaw in the Payroll app allowed for a leak of credentials and similarly is what brought Colonial Pipeline to a complete stop of operation during April of 2021. In the cases studies that were reviewed, both victims were subject to ransomware, and in each of these cases a combination of outdated software, poor configurations and weak digital hygiene enabled attackers to escalate privileges and exfiltrate or tamper with sensitive data.

RQ 2: To be able to effectively mitigate vulnerabilities both technical controls and human-centric practices have to be put in place. Automating a robust patch management process prevents exploitation of known CVEs. At the application layer, enforcing input validation and committing to using only parameterized statements instead of processing each query in the backend stops SQL Injection right at the source. By enforcing unique and strong credentials and implementing IDS/IPS an attack chain can be cut short significantly. Finally, digital hygiene education (phishing awareness and secure password management) make users and employees a frontline defense against social engineering and credential misuse.

In essence, this thesis demonstrates that a single vulnerable service in a system can lead to a full system takeover. By implementing automated updates, secure coding practices, system monitoring and user-focused training, SMEs can significantly strengthen their resilience against the same type of threats that are found in both the lab and out in the wild.

7.1 Future Direction of Studies

This thesis has demonstrated how a single vulnerable service in a Metasploitable 3 lab allowed for full compromise of the entire system and its contents. However, the study has also encountered several boundaries and limitations that encourage more comprehensive exploration. Tying back to the limitations discussed in Section 6.3, this study proposes the following paths for future research:

I. Diverse and Dynamic Environments

The static snapshot of Metasploitable 3 (Ubuntu 14.04) used as the target machine in the experiments offered repeatability, but real-world networks are considerably more dynamic. Future studies should perform similar experiments across a range of different environments, both in terms of operating systems (including Windows, newer Linux distributions, and containerized environments) and within microservice or cloud architecture. Implementing firewalls, virtual network segmentation, and VPN gateways would provide insight into how layered defense mechanisms affect the potential of pivoting an attack chain from one “linchpin” vulnerability.

II. Lime SME Case Studies

Researchers could partner with willing small and medium-sized enterprises to conduct assessments of their patch-management workflows, credential policies, and phishing awareness programs. This would allow for moving beyond static lab environments. By regularly scanning, exploiting (in a strictly ethical capacity), and then introducing proposed mitigations, it would make it possible to measure real improvements in resilience and gather beneficial data. Furthermore, this would improve recommendations, both technical and human-centric.

III. Human Factors and Digital Hygiene Interventions

This thesis emphasized credential reuse as a critical enabler of rapid and comprehensive compromise. In order to investigate the human factor in a more direct manner, future studies could run simulated phishing campaigns and enroll and monitor employee adoption of password managers. By combining those behavioral experiments with vulnerability assessments, one could potentially quantify the scope of how “good digital hygiene” actually affects threat actors’ window of opportunity.

By broadening the technical scope, analyzing and testing on live environments, and thoroughly evaluating human-centric factors, future research can fill the gap between lab-bound vulnerability analysis and real-world cyber security for small and medium-sized enterprises.

References

- [1] M. El-Hajj and Z. A. Mirza, "Protecting Small and Medium Enterprises: A specialized cybersecurity risk assessment framework and tool," *Electronics (Basel)*, vol. 13, no. 19, p. 3910, Oct. 2024.
- [2] A. Fikry, M. I. Hamzah, Z. Hussein, A. J. Abdul, and K. A. Abu Bakar, "Defining the beauty of cyber hygiene: A retrospective look," *IEEE Eng. Manag. Rev.*, vol. 52, no. 2, pp. 174–180, Apr. 2024.
- [3] A. R. Neigel, V. L. Claypoole, G. E. Waldfogle, S. Acharya, and G. M. Hancock, "Holistic cyber hygiene education: Accounting for the human factors," *Comput. Secur.*, vol. 92, no. 101731, p. 101731, May 2020.
- [4] D. Lappas and P. Karampelas, "Designing an email attack by analysing the victim's profile. An alternative anti-phishing training method," *Proc. Eur. Conf. Inf. Warf. Secur.*, vol. 22, no. 1, pp. 257–266, Jun. 2023.
- [5] P. Bhatt, M. S. Obaidat, G. Dangwal, A. K. Das, M. Wazid, and B. Sadoun, "Machine learning-based security mechanism for detecting phishing attacks," in *2024 International Conference on Communications, Computing, Cybersecurity, and Informatics (CCCI)*, IEEE, Oct. 2024, pp. 1–6.
- [6] B. Gogoi and T. Ahmed, "Phishing and Fraudulent Email Detection through Transfer Learning using pretrained transformer models," in *2022 IEEE 19th India Council International Conference (INDICON)*, IEEE, Nov. 2022. doi: 10.1109/indicon56171.2022.10040097.
- [7] R. S. Mohamed Ali and R. A. Abduhameed, "Phishing email detection: Survey," in *Lecture Notes in Networks and Systems*, in Lecture notes in networks and systems. , Cham: Springer Nature Switzerland, 2024, pp. 551–570.
- [8] S. Priya, D. Gutema, and S. Singh, "A comprehensive survey of recent phishing attacks detection techniques," in *2024 5th International Conference on Innovative Trends in Information Technology (ICITIIT)*, IEEE, Mar. 2024. doi: 10.1109/icitiit61487.2024.10580446.
- [9] A. Dabit, Q. A. Al-Haija, and M. Al-Fayoumi, "Identifying weaknesses: A guide to conducting an effective network vulnerability assessment," in *2023 24th International Arab Conference on Information Technology (ACIT)*, IEEE, Dec. 2023, pp. 1–6.
- [10] "Website." [Online]. Available: <https://www.colpipe.com/about-us/>
- [11] J. Beerman, D. Berent, Z. Falter, and S. Bhunia, "A review of colonial pipeline ransomware attack," in *2023 IEEE/ACM 23rd International Symposium on Cluster, Cloud and Internet Computing Workshops (CCGridW)*, IEEE, May 2023. doi: 10.1109/ccgridw59191.2023.00017.
- [12] M. Alanazi, A. Mahmood, and M. J. M. Chowdhury, "ICS-LTU2022: A dataset for ICS vulnerabilities," *Comput. Secur.*, vol. 148, no. 104143, p. 104143, Jan. 2025.
- [13] O. Soner, G. Kayisoglu, P. Bolat, and K. Tam, "An investigation of ransomware incidents in the maritime industry: Exploring the key risk factors," *Proc. Inst. Mech. Eng. O. J. Risk Reliab.*, Oct. 2024, doi: 10.1177/1748006x241283093.
- [14] S. Bhunia, M. Blackert, H. Deal, A. DePero, and A. Patra, "Analyzing the 2021 Kaseya ransomware attack: Combined spearphishing through SonicWall SSLVPN vulnerability," *IET Inf. Secur.*, vol. 2025, no. 1, Jan. 2025, doi: 10.1049/ise2/1655307.
- [15] C. Pu et al., "A functional model and analysis of next generation malware attacks and defenses," in *2021 Third IEEE International Conference on Trust, Privacy and Security in Intelligent Systems and Applications (TPS-ISA)*, IEEE, Dec. 2021. doi: 10.1109/tpsisa52974.2021.00023.
- [16] "Important Notice August 4th, 2021," Kaseya HelpDesk. [Online]. Available: <https://helpdesk.kaseya.com/hc/en-gb/articles/4403440684689-Important-Notice-August-4th-2021>
- [17] "Box." Accessed: Mar. 26, 2025. [Online]. Available: <https://kaseya.app.box.com/s/p9b712dcwfsnhuq2jmx31ibsuef6xict>
- [18] H. Ghanbari, K. Koskinen, and Y. Wei, "From SolarWinds to Kaseya: The rise of supply chain attacks in a digital world," *J. Inf. Technol. Teach. Cases*, Nov. 2024, doi: 10.1177/20438869241299823.
- [19] "Nu är alla Coops butiker öppna," Coop Pressrum. Accessed: Mar. 26, 2025. [Online]. Available: <https://pressrum.coop.se/nu-ar-alla-coops-butiker-oppna>

- [20] M. Abdelgawad and P. W. C. Prasad, "Advanced persistent threats—techniques, detection and defences," in *Lecture Notes in Electrical Engineering*, in Lecture notes in electrical engineering. , Cham: Springer Nature Switzerland, 2024, pp. 143–167.
- [21] R. Bhardwaj, N. Kumar, H. Kour, N. Verma, and A. Ashish, "Analysis of advanced persistent threat attacks, lifecycle, and counter measures: A comprehensive review," in *Lecture Notes in Electrical Engineering*, in Lecture notes in electrical engineering. , Singapore: Springer Nature Singapore, 2024, pp. 143–153.
- [22] R. Kumar and S. Pandey, "A cyber-risk management schema for classifying literature on advanced persistent threats," in *2025 17th International Conference on COMMunication Systems and NETworks (COMSNETS)*, IEEE, Jan. 2025, pp. 1317–1322.
- [23] B. Genge, P. Haller, and A.-S. Roman, "E-APTDetect: Early advanced persistent threat detection in critical infrastructures with dynamic attestation," *Appl. Sci. (Basel)*, vol. 13, no. 6, p. 3409, Mar. 2023.
- [24] D. Dave, G. Sawhney, P. Aggarwal, N. Silswal, and D. Khut, "The new frontier of cybersecurity: Emerging threats and innovations," in *2023 29th International Conference on Telecommunications (ICT)*, IEEE, Nov. 2023, pp. 1–6.
- [25] S. Sakib, M. A. K. Raiaan, N. M. Fahad, M. S. H. Mukta, A. Al Mamun, and S. Chowdhury, "A review of the evaluation of ransomware: Human error or technical failure?," in *2023 International Conference on Information and Communication Technology for Sustainable Development (ICICT4SD)*, IEEE, Sep. 2023. doi: 10.1109/icict4sd59951.2023.10303580.
- [26] Z. Li and Q. Liao, "Ransomware 2.0," in *Proceedings of the 15th International Conference on Availability, Reliability and Security*, New York, NY, USA: ACM, Aug. 2020. doi: 10.1145/3407023.3409196.
- [27] S. Algarni, "Cybersecurity attacks: Analysis of 'WannaCry' attack and proposing methods for reducing or preventing such attacks in future," in *Advances in Intelligent Systems and Computing*, in Advances in intelligent systems and computing. , Singapore: Springer Singapore, 2021, pp. 763–770.
- [28] J. Manzoor, A. Waleed, A. F. Jamali, and A. Masood, "Cybersecurity on a budget: Evaluating security and performance of open-source SIEM solutions for SMEs," *PLOS ONE*, vol. 19, no. 3, p. e0301183, Mar. 2024.
- [29] V. A. Mehri, P. Arlos, and E. Casalicchio, "Automated patch management: An empirical evaluation study," in *2023 IEEE International Conference on Cyber Security and Resilience (CSR)*, IEEE, Jul. 2023, pp. 321–328.
- [30] C. Manzano, G. Márquez, and H. Astudillo, "Security mechanisms used in systems based on zero trust architecture: A systematic mapping," in *2024 L Latin American Computer Conference (CLEI)*, IEEE, Aug. 2024, pp. 1–10.
- [31] S. Karagiannis *et al.*, "AI-powered penetration testing using shennina: From simulation to validation," in *Proceedings of the 19th International Conference on Availability, Reliability and Security*, New York, NY, USA: ACM, Jul. 2024, pp. 1–7.
- [32] A. C. Moreno *et al.*, "Analysis of Autonomous Penetration Testing Through Reinforcement Learning and Recommender Systems," *Sensors (Basel)*, vol. 25, no. 1, Jan. 2025, doi: 10.3390/s25010211.
- [33] S.-S. Yoon, D.-Y. Kim, K.-K. Kim, and I.-C. Euom, "Vulnerability exploitation risk assessment based on offensive security approach," *Appl. Sci. (Basel)*, vol. 13, no. 22, p. 12180, Nov. 2023.
- [34] M. Alhamed and M. M. H. Rahman, "A systematic literature review on penetration testing in networks: Future research directions," *Appl. Sci. (Basel)*, vol. 13, no. 12, p. 6986, Jun. 2023.
- [35] S. Armoogum *et al.*, "A comprehensive review of cyber hygiene practices in the workplace for enhanced digital security," *JOIV Int. J. Inform. Vis.*, vol. 9, no. 1, p. 137, Jan. 2025.
- [36] "Kali Linux," Kali Linux. Accessed: Mar. 14, 2025. [Online]. Available: <https://www.kali.org/>
- [37] "Nmap: the Network Mapper - Free Security Scanner." Accessed: Mar. 14, 2025. [Online]. Available: <https://nmap.org/>
- [38] "OpenVAS - Open Vulnerability Assessment Scanner." Accessed: Mar. 14, 2025. [Online]. Available: <https://www.openvas.org/>
- [39] S. Raj and N. K. Walia, "A study on metasploit framework: A pen-testing tool," in *2020 International Conference on Computational Performance Evaluation (ComPE)*, IEEE, Jul. 2020.

doi: 10.1109/compe49325.2020.9200028.

- [40] S. Rahalkar, *Metasploit 5.0 for Beginners: Perform penetration testing to secure your IT environment against threats and vulnerabilities, 2nd Edition*. Packt Publishing Ltd, 2020.
- [41] “Metasploit Rising,” Rapid7. Accessed: Mar. 11, 2025. [Online]. Available: <http://www.rapid7.com/blog/post/2009/10/21/metasploit-rising/>
- [42] “Metasploit,” TryHackMe. Accessed: Mar. 11, 2025. [Online]. Available: <https://tryhackme.com/module/metasploit>
- [43] “A step-by-step guide to the Metasploit Framework,” Hack The Box. Accessed: Mar. 11, 2025. [Online]. Available: <https://www.hackthebox.com/blog/metasploit-tutorial>
- [44] “GitHub - rapid7/metasploit-framework: Metasploit Framework,” GitHub. Accessed: Mar. 11, 2025. [Online]. Available: <https://github.com/rapid7/metasploit-framework>
- [45] M. Sivamanikanta, M. A. M. Abbas, and P. Das, “Exploring the capabilities of the metasploit framework for effective penetration testing,” in *Data Science and Network Engineering*, in Lecture notes in networks and systems. , Singapore: Springer Nature Singapore, 2024, pp. 457–471.
- [46] A. B. Samgir, V. Gutte, K. Kolhe, and D. R. Patil, “Automated penetration testing architecture using metasploit and OWASP ZAP for web applications,” in *2024 2nd International Conference on Sustainable Computing and Smart Systems (ICSCSS)*, IEEE, Jul. 2024, pp. 649–657.
- [47] G. P. Bhatraju, U. Shanmugam, B. Indira, and U. Nandhini, “Malware analysis for proactive defence on cyber threat vulnerabilities,” in *2023 Innovations in Power and Advanced Computing Technologies (i-PACT)*, IEEE, Dec. 2023. doi: 10.1109/i-pact58649.2023.10434439.
- [48] B. K. Jena, “A Look At ‘What Is Metasploitable’, A Hacker’s Playground Based On Ubuntu Virtual Machines,” Simplilearn.com. Accessed: Mar. 10, 2025. [Online]. Available: <https://www.simplilearn.com/tutorials/cyber-security-tutorial/what-is-metasploit>
- [49] W. Chen, “Metasploitable3: An Intentionally Vulnerable Machine for Exploit Testing,” Rapid7. Accessed: Mar. 14, 2025. [Online]. Available: <http://www.rapid7.com/blog/post/2016/11/15/test-your-might-with-the-shiny-new-metasploitable3/>
- [50] “GitHub - rapid7/metasploitable3: Metasploitable3 is a VM that is built from the ground up with a large amount of security vulnerabilities,” GitHub. Accessed: Mar. 14, 2025. [Online]. Available: <https://github.com/rapid7/metasploitable3>
- [51] R. Chen, C. Lyu, W. Wang, H. Lin, and Q. Lin, “A containerized IoT simulation environment for network warfare training,” in *2024 IEEE International Conferences on Internet of Things (iThings) and IEEE Green Computing & Communications (GreenCom) and IEEE Cyber, Physical & Social Computing (CPSCom) and IEEE Smart Data (SmartData) and IEEE Congress on Cybermatics*, IEEE, Aug. 2024, pp. 1–8.
- [52] I. Delgado, E. Sancristobal, S. Martin, and A. Robles-Gómez, “Exploring IoT Vulnerabilities in a Comprehensive Remote Cybersecurity Laboratory,” *Sensors (Basel)*, vol. 23, no. 22, Nov. 2023, doi: 10.3390/s23229279.
- [53] K. Okumura and R. Kobayashi, “Reducing testing time in penetration test automation by using EPSS and parallelization,” in *2024 Twelfth International Symposium on Computing and Networking Workshops (CANDARW)*, IEEE, Nov. 2024, pp. 286–292.
- [54] “Main Page.” Accessed: Mar. 20, 2025. [Online]. Available: https://linux-kvm.org/page/Main_Page
- [55] “QEMU.” Accessed: Mar. 20, 2025. [Online]. Available: <https://www.qemu.org/>
- [56] “libvirt.” Accessed: Mar. 20, 2025. [Online]. Available: <https://wiki.archlinux.org/title/Libvirt>
- [57] “Securely run operating systems on your Mac,” UTM. Accessed: May 02, 2025. [Online]. Available: <https://mac.getutm.app/>